$ ./hunt --hipotesis clickfix --sin-alertas

CAZANDO LO QUE NO SABÉS QUE NO SABÉS

Threat hunting guiado por inteligencia, sobre un caso real.

David Pérez · Threat Intelligence & Threat Hunting · Security Advisor

2 de octubre 2026 · Sala Mayo, Paraná

Sobre el autor

A **Trayectoria** SOC Analyst (L1, L2) → Phishing Analyst → Threat Intelligence, Threat Hunter e Incident Response.Lider SOC

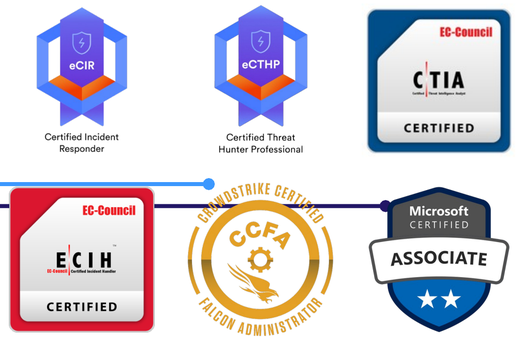
B **Roles en el Estado** Inteligencia Criminal (Area Reunión de Información) Jefe Dpto Analisis y Contrainteligencia — Ministerio de Justicia Bs As.

C **Temas que sigo** Threat Intelligence, Ransomware, ecosistema de acceso inicial y Leaks en LATAM.

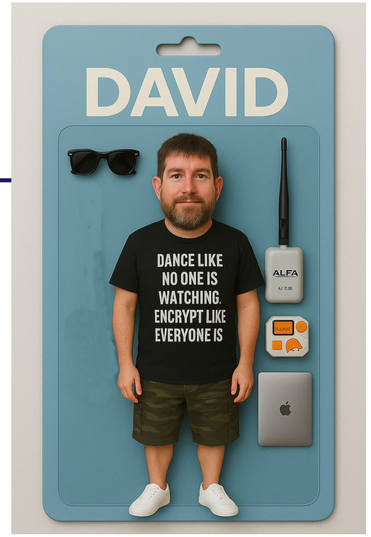
D **Temas que sigo** Threat Intelligence, Ransomware, ecosistema de acceso inicial y Leaks en LATAM.

E **Certificaciones** eCIR · eCTHP (INE Security) · CTIA · ECIH (EC-Council) · CCFA (CrowdStrike) · SC-200 (Microsoft).

F **Contacto** @anakinswal · github.com/Ank1nskywalker/talks · perez.edav@gmail.com



Certificaciones



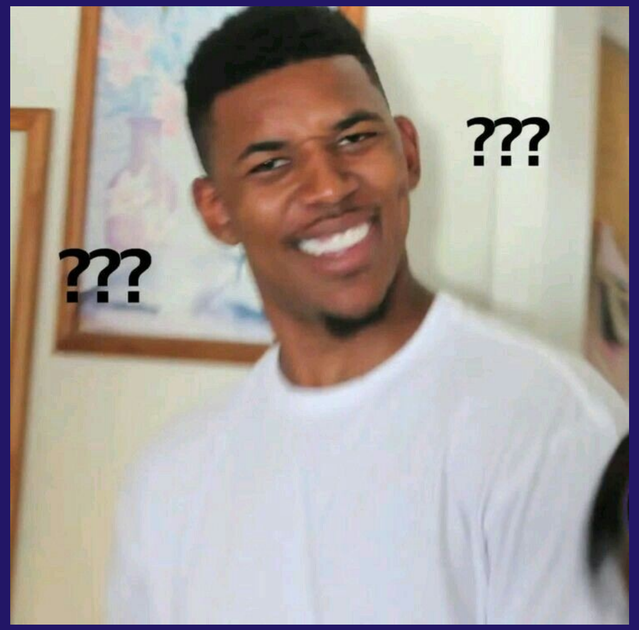
¿Lo que no sabemos que no sabemos?



“Hay cosas que sabemos que sabemos. Hay cosas que sabemos que no sabemos. Y hay cosas que no sabemos que no sabemos.”

Donald Rumsfeld · Secretario de Defensa de EE. UU. · Conferencia de prensa, febrero de 2002, en plena antesala de la guerra de Irak.

La frase se convirtió en un marco de gestión de riesgo para analistas de inteligencia: separa lo confirmado, lo que hay que investigar y lo que ni siquiera sabemos que existe.



Todo SOC tiene una. La pregunta es si alguien sale a buscarla.

Known / Unknown: El modelo Rumsfeld

KNOWN KNOWNS
Realidad operativa

01

Lo que sabemos que sabemos.

ESCENARIO

ClickFix está documentado: falso CAPTCHA, Win+R, Ctrl+V, Enter. Los IOCs de las campañas circulan en feeds y el EDR bloquea las IPs que ya están en listas. Pero el comando lo ejecuta el propio usuario, con PowerShell firmado por Microsoft.

Aca vive el SOC reactivo.

KNOWN UNKNOWNS
Incertidumbre estratégica

02

Sabemos que hay cosas que no sabemos.

ESCENARIO

Sabemos que ClickFix fue el 47 % de los accesos iniciales que vio Microsoft y que 4 de cada 5 llegan desde un buscador. No sabemos si alguno de nuestros usuarios ya pegó un comando: queda registrado como actividad del usuario, con riesgo “info”.

Aca viven los PIRs (Priority Intelligence Requirement) y el threat hunting.

UNKNOWN UNKNOWNS
Cisne negro cibernético

03

Lo que no sabemos que no sabemos.

ESCENARIO

La próxima variante del truco, la que todavía no tiene nombre. Ya pasó con FileFix (pegar en la barra de direcciones del Explorador) y con la versión para macOS (Terminal): cada una esquiva la regla que escribiste para la anterior.

Aca vive la inteligencia anticipatoria.

El objetivo de CTI: mover lo máximo posible de Unknown a Known — y aceptar lo que no podés mover.

Los tres cuadrantes, llevados al hunting

KNOWN KNOWNS 01

Lo que sabemos que sabemos

IOCs, reglas, listas de reputación.

Una IP que ya está en una lista de reputación: el EDR la bloquea solo.

Acá vive el SOC reactivo.

KNOWN UNKNOWNS 02

Sabemos que hay cosas que no sabemos

Técnicas conocidas que no sabés si te pasaron.

ClickFix está en todos los reportes. ¿Nos pasó? Si pasó, está en la telemetría, con riesgo “info”. Hay que salir a buscarlo.

Acá vive el hunting por hipótesis.

UNKNOWN UNKNOWNS 03

Lo que no sabemos que no sabemos

Lo que aparece recién cuando salís a cazar.

Lo que vamos a encontrar en la demo buscando otra cosa.

Acá nace la próxima hunt.

El trabajo del hunter: pasar lo amarillo a verde, y usar lo que encuentra para achicar lo naranja.

Fuente: adaptación propia del modelo de Rumsfeld (2002). Ejemplos del caso que vamos a recorrer en la demo.

¿Qué NO es threat hunting?

Cuatro cosas que se confunden con cazar, antes de seguir.

NO es esperar la alerta

Si arrancás cuando suena la alarma, estás respondiendo, no cazando.

NO es hacer triage

Revisar la cola del SIEM es necesario. Pero son alertas que alguien ya escribió.

NO es barrer IOCs

Buscar los hashes de un feed es un barrido: sirve, dura poco y no requiere hipótesis.

NO es respuesta a incidentes

IR arranca con una certeza (pasó algo). El hunting arranca con una duda.

Threat hunting ES el proceso proactivo e iterativo de buscar, en redes y endpoints, amenazas que evadieron los controles existentes.

Asume la brecha

Parte de que algo ya pasó los controles.

Arranca de una hipótesis

Una pregunta que los datos pueden confirmar o refutar.

Termina en algo nuevo

Una detección, visibilidad que no tenías o una contención.

Fuente: definición adaptada de Sqrrl, “A Framework for Cyber Threat Hunting” · D. Bianco et al., PEAK Threat Hunting Framework, Splunk SURGe (2023). Links en el anexo de fuentes.

Tres formas de cazar

POR INTELIGENCIA

LA DE HOY

Intelligence-driven

- **Arranca de afuera**

Un reporte, un feed o un PIR te dice qué está pasando en el mundo. Traducís sus TTPs, no sus IOCs, en una pregunta para tu flota.

EJEMPLO

Microsoft: ClickFix es el 47 % de los accesos iniciales. ¿Alguien de la flota pegó un comando?

POR HIPÓTESIS

Hypothesis-driven · ATT&CK

- **Arranca de una idea**

Sin un reporte que la dispare: partís de ATT&CK o de tu experiencia. “Si el adversario hizo X, lo veo en Y.”

EJEMPLO

Si alguien persiste en el navegador, un proceso que no es Chrome va a escribir su perfil.

POR LÍNEA BASE

Baseline · análisis exploratorio

- **Arranca de los datos**

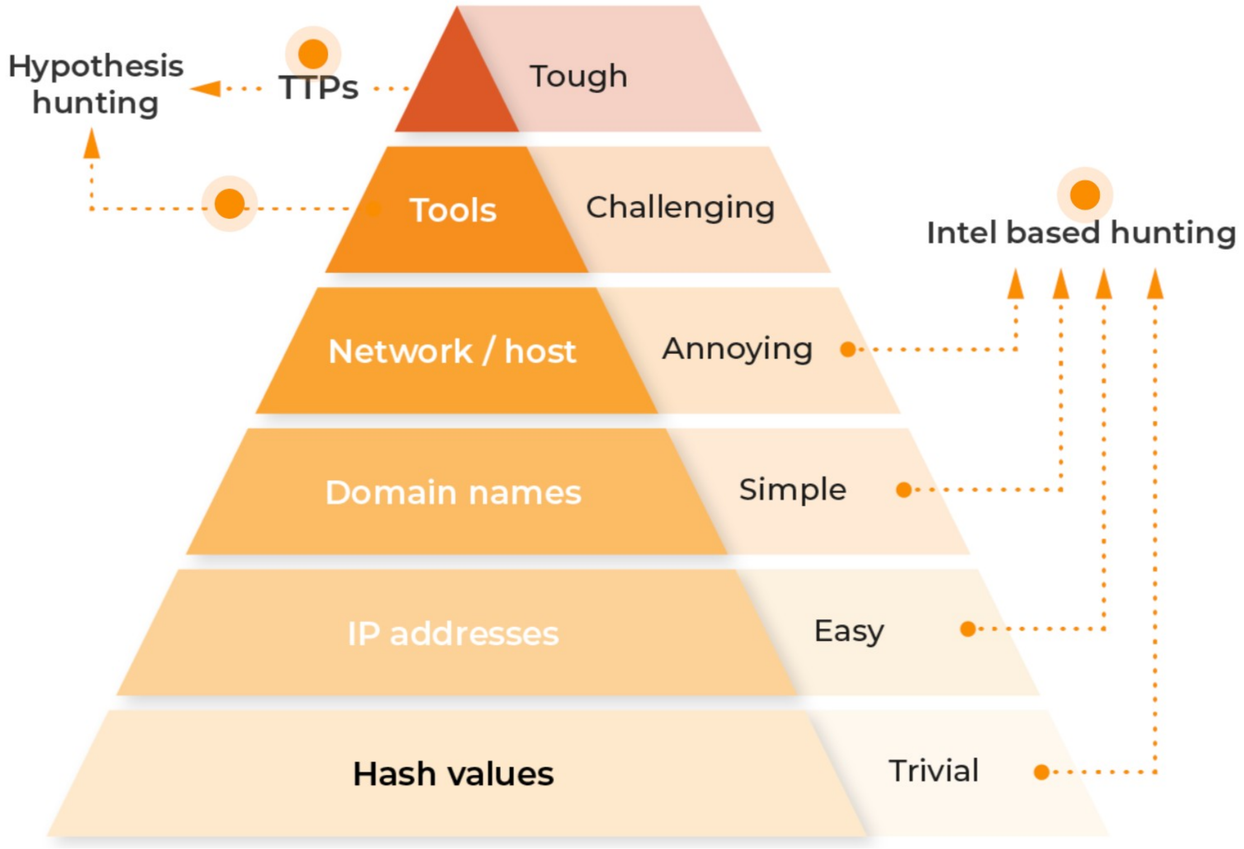
Definís lo normal y cazás lo raro: stack counting, rareza en la flota, lo que aparece una sola vez.

EJEMPLO

¿Cuántas veces al mes corre csc.exe sin argumentos en 3.000 equipos?

Adaptado de PEAK (Bianco et al., Splunk SURGe, 2023), que trata la inteligencia como fuente de hipótesis y suma un tercer tipo: asistida por modelos (M-ATH). Links en el anexo de fuentes.

Threat Hunting la pirámide del Dolor





Fuente: D. J. Bianco, “The Pyramid of Pain” (2013). Links en el anexo de fuentes.

El ciclo de una hunt

Cinco pasos, tres fases. El último alimenta al primero.

PREPARAR		EJECUTAR		ACTUAR
1	**2**	**3**	**4**	**5**
Hipótesis	**Datos**	**Query**	**Análisis**	**Reporte**
¿Qué haría el adversario y dónde lo vería?	**¿Tengo la telemetría? ¿Qué no veo?**	**¿Encuentra lo que sé que existe?**	**¿Malicioso, benigno o no concluyente?**	**¿Qué cambia mañana?**
EN EL CASO *Usuarios pegaron un comando ClickFix.*	**EN EL CASO** *RunMRU, procesos y scripts del EDR. El portapapeles, no.*	**EN EL CASO** *Probada contra un evento conocido.*	**EN EL CASO** *1 equipo confirmado, 4 aciertos.*	**EN EL CASO** *3 detecciones, 1 brecha, 1 hipótesis nueva.*

El reporte vuelve al paso 1: cada hunt deja la próxima hipótesis. En el caso, la extensión del navegador nos dio una.

Fuente: fases Preparar / Ejecutar / Actuar del framework PEAK (Splunk SURGe, 2023), con ejemplos del caso de la demo. Links en el anexo de fuentes.

ClickFix: por qué es la hipótesis de hoy

47 %

de los accesos iniciales que vio Microsoft Defender Experts en el último año fueron ClickFix. Phishing: 35 %.

Microsoft, MDDR 2025

+517 %

entre el 2.º semestre de 2024 y el 1.º de 2025. Pasó a ser el segundo vector, detrás del phishing.

ESET, H1 2025

4 de 5

payloads de ClickFix interceptados en 2026 llegaron desde un buscador (Google, Bing), no desde el mail.

Push Security, 2026

17.000+

URLs con páginas falsas de verificación analizadas; unas 3.000 activas al momento del estudio.

CTM360 vía SecNews, sep 2026

CÓMO FUNCIONA

1 Buscás algo

Música, un software, un "fix". Resultado en Google.

2 Un error falso

CAPTCHA, "verificá que sos humano", "no se pudo cargar".

3 Copia al portapapeles

La página ya copió un comando de PowerShell.

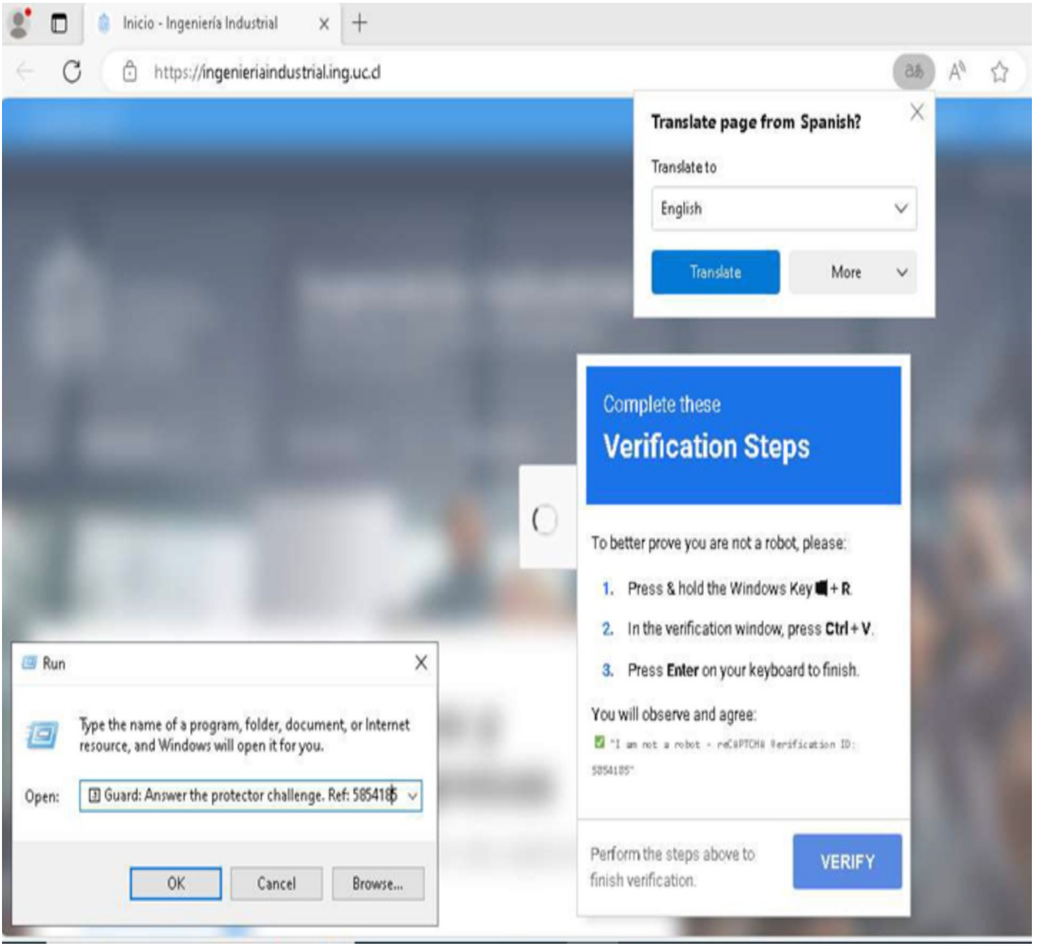
4 Win+R · Ctrl+V · Enter

La víctima ejecuta. No hay adjunto ni exploit.

Para un hunter: entra por la búsqueda, no por el mail. El gateway de correo no lo ve; el EDR sí, pero lo registra como actividad del usuario.

Fuentes: Microsoft, Digital Defense Report 2025 (p. 37) · ESET Threat Report H1 2025 · Push Security, “The state of ClickFix” (sep. 2026) · CTM360, vía SecNews (sep. 2026). Links en el anexo de fuentes.

ClickFix: por qué es la hipótesis de hoy





Fuentes: Microsoft, Digital Defense Report 2025 (p. 37) · ESET Threat Report H1 2025 · Push Security, “The state of ClickFix” (sep. 2026) · CTM360, vía SecNews (sep. 2026). Links en el anexo de fuentes.

La hipótesis del ejercicio: Este hunt se construye sobre un caso real.

EL EJERCICIO

1 Telemetría real
Un día de eventos del EDR de una flota real, anonimizado.

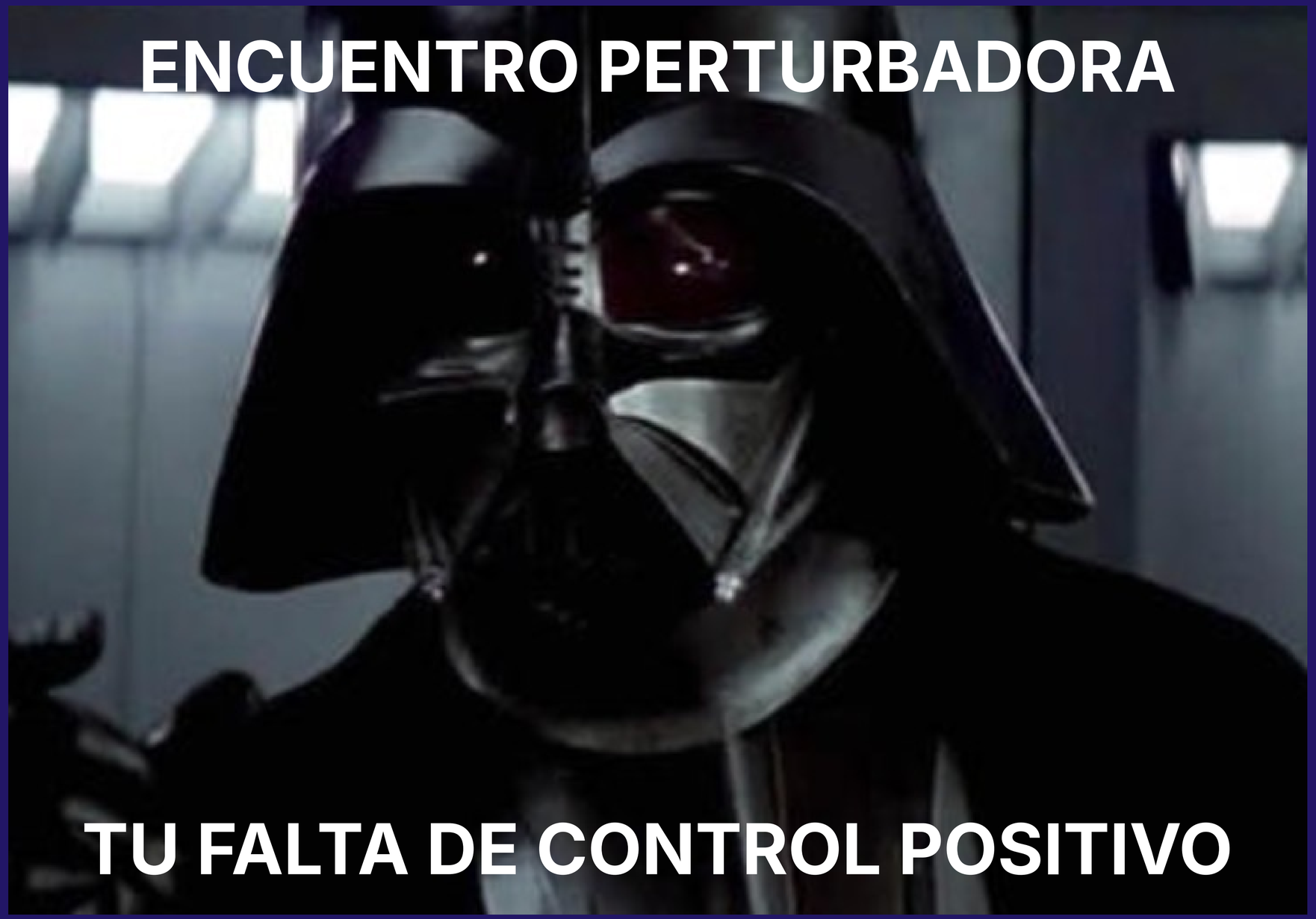
2 Sin mirar alertas
Hacemos de cuenta que el SOC no recibió ninguna.

3 Solo la inteligencia
ClickFix es masivo y llega por buscadores. ¿Nos pasó?

HIPÓTESIS *Si algún usuario de la flota pegó en Win+R un comando desde un señuelo ClickFix, vamos a ver en el EDR una escritura de explorer.exe en la clave RunMRU con un comando de descarga (PowerShell, mshta, curl), y ese mismo comando ejecutándose segundos después.*

Por qué es creíble	Llega por buscadores, no por mail: le puede pasar a cualquiera. Y Win+R deja rastro en RunMRU aunque cambien IPs y hashes.
Fuente de datos	Registro (RunMRU) y procesos del EDR, en toda la flota: los eventos, no las alertas.
Control positivo	Antes de dar algo por refutado, probar la query con un Win+R de prueba en un equipo de laboratorio.
La confirma	Un equipo con un comando de descarga en RunMRU, seguido del proceso que ese comando lanza.
La refuta	Cero escrituras sospechosas en RunMRU, con la query ya probada contra un control positivo.
Brecha conocida	RunMRU solo ve lo que se pega en Win+R. Si lo pegan en el Explorador (FileFix) no veremos nada en una alerta.

ATT&CK: T1204.004 (Malicious Copy and Paste) → T1059.001 (PowerShell). Evidencia: HKCU\…\Explorer\RunMRU. Alcance: toda la flota con EDR, últimos 30 días.



Cero resultados sin control positivo no prueban nada.

EL EJERCICIO

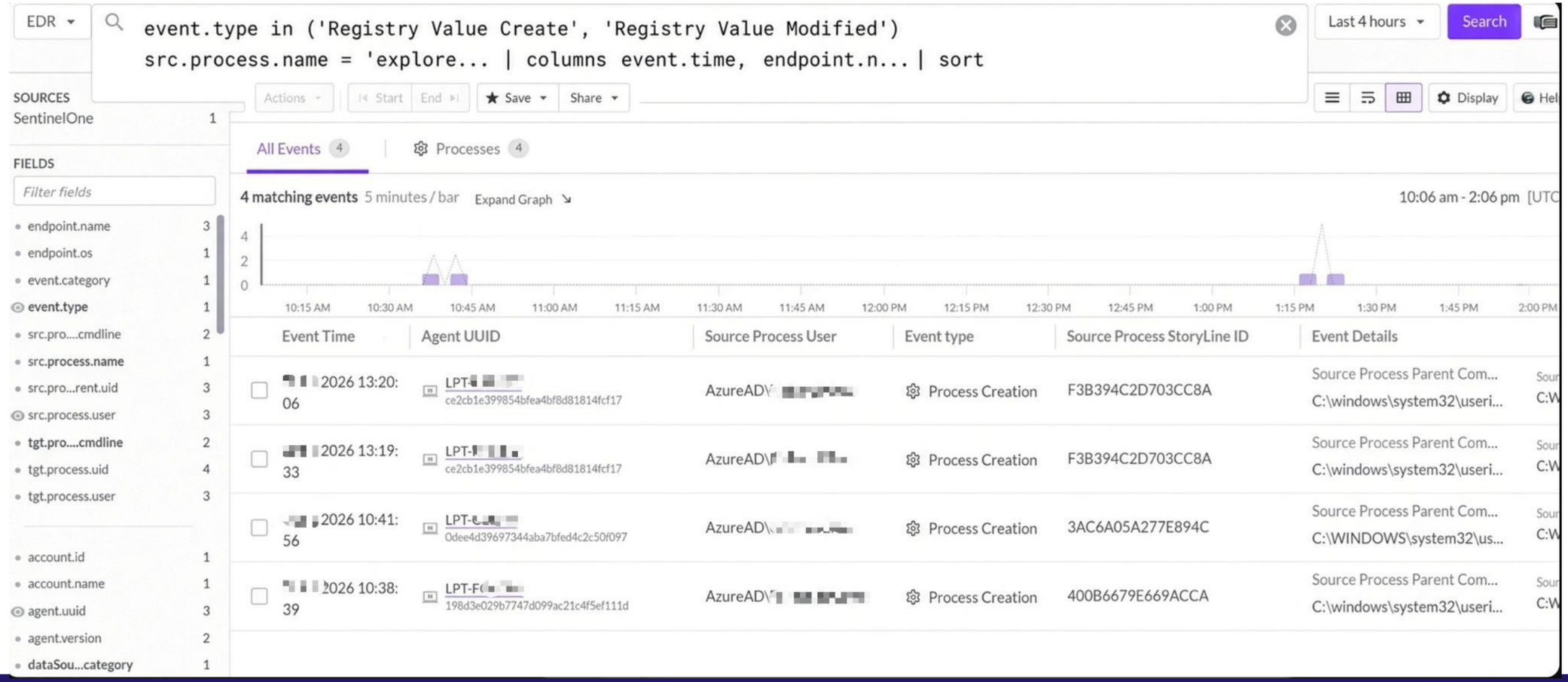
Telemetría real. Cero alertas. ¿Lo encontramos?

Los eventos del EDR de una empresa de LATAM, de un día real. Hagamos de cuenta que el SOC no recibió ninguna alerta, y salgamos a cazar con la hipótesis.

Datos reales, anonimizados: usuarios, equipos, IPs y dominios reemplazados.

¿Alguien pegó un comando?

QUERY · SentinelOne (Singularity Data Lake)



¿Alguien pegó un comando?

Etapa 1 Carga funciones de Windows y oculta la ventana de la consola. Por eso el user no vio nada y reintentó

Etapa 2 Anula las advertencias de Windows para archivos descargados descargar un MSI de **http://86.109.75.7/app/40152518488f/235235.msi**. Lo guarda en %TEMP%, le quita la marca de descargado de internet (Unblock-File) y lo instala con msiexec /i /qn /norestart con la ventana oculta. Al final se borra a sí mismo

Etapa 3 Modifica Chrome e instala una Extensión maliciosa cargada como unpacked y que no viene de la Chrome Web Store (**from_webstore: false**). Inyecta content scripts en en todos los frames lo que le permite **leer y modificar cualquier página**. La extensión se comunica a un host en el puerto 4343, y puede: **robar cookies, el historial, los marcadores, las descargas, la lista de pestañas y capturas de pantalla del navegador; también puede escribir cookies, lo que habilita el secuestro de sesiones**.

Una IP en decimal

3405803783 = 203.0.113.7. Conviértanla en vivo: evade filtros que buscan “x.x.x.x”.





Save to Google Drive (Google LLC) | Save to Google Drive (Google inc.)

¿Cómo se queda? Persistencia en el navegador

QUERY · SentinelOne (Singularity Data Lake)

```
event.type = 'File Modification'
and tgt.file.path contains:anycase
  'User Data'
and tgt.file.path contains 'Preferences'
and not src.process.name in:anycase
  ('chrome.exe','msedge.exe',
  'setup.exe','GoogleUpdater.exe')
```

RESULTADO · campos relevantes, anonimizados

src.process.name	**csc.exe (inyectado, sin argumentos)**
tgt.file.path	…\Chrome\User Data\Default\ **Secure Preferences**
qué cambió	registra una extensión y recalcula la firma que la protege
persistencia	**la única del incidente**

Una “Save to Google Drive” falsa

Autor “Google inc.”, cargada como unpacked desde una carpeta con nombre al azar en %LOCALAPPDATA%.

Qué roba

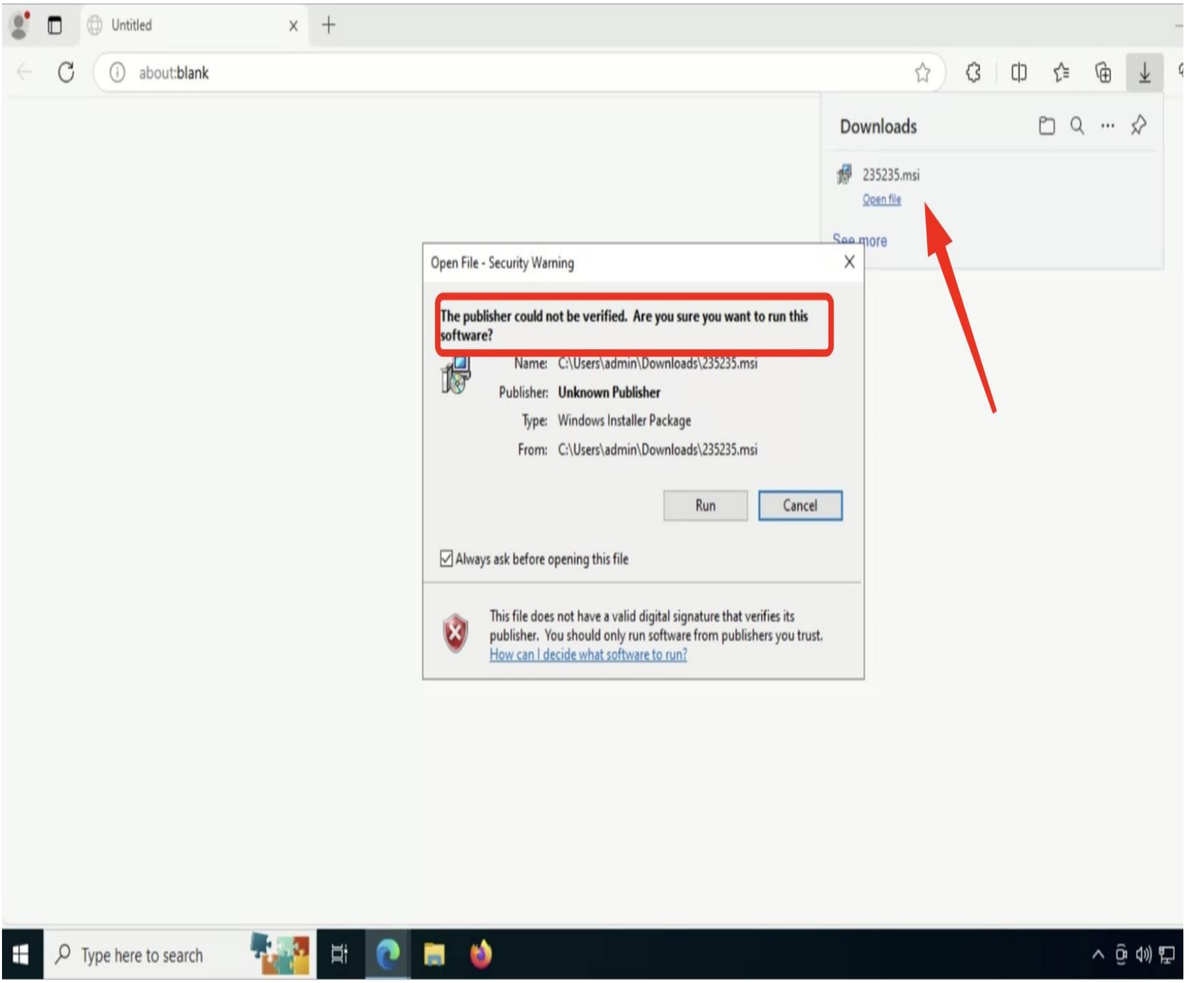
Cookies, historial, marcadores, pestañas y capturas. También puede escribir cookies: robo de sesión.

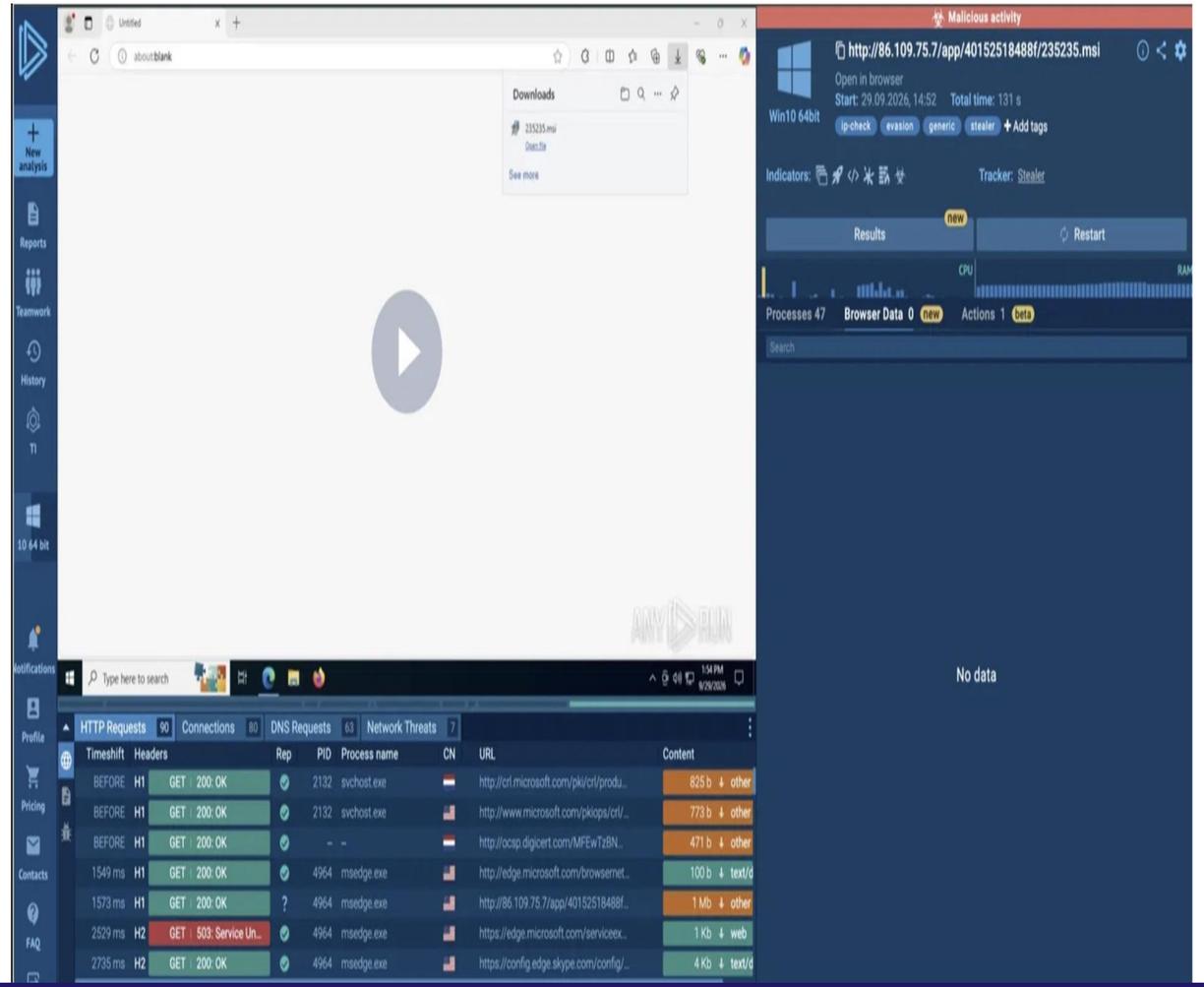
Y miente

Su fecha de instalación estaba falsificada un año atrás. Los archivos en disco la desmienten.

No había persistencia en el sistema operativo. Estaba en el navegador, y el canal de la extensión era un tercer C2 distinto.

Sandbox


Untitled
about:blank
Downloads
235235.msi
Open file
See more
Open File - Security Warning
The publisher could not be verified. Are you sure you want to run this software?
Name: C:\Users\admin\Downloads\235235.msi
Publisher: Unknown Publisher
Type: Windows Installer Package
From: C:\Users\admin\Downloads\235235.msi
Run
Cancel
Always ask before opening this file
This file does not have a valid digital signature that verifies its publisher. You should only run software from publishers you trust.
How can I decide what software to run?
Type here to search


Malicious activity
http://86.109.75.7/app/40152518488f/235235.msi
Open in browser
Start: 29.09.2026, 14:52 Total time: 131 s
Win10 64bit
ip-check evasion generic stealer + Add tags
Indicators:
Tracker: Stealer
Results
Restart
Processes 47 Browser Data 0 Actions 1
No data
HTTP Requests 90 Connections 80 DNS Requests 63 Network Threats 7
Timeshift Headers Rep PID Process name CN URL Content

La realidad: la alerta llegó en el paso 7

T+0:00	T+0:03	T+0:05	T+0:07	T+0:24	T+0:26	T+4:51
1	2	3	4	5	6	7
Pega el comando Queda en RunMRU; PowerShell descarga un script.	**Consola oculta** La ventana desaparece. La usuaria cree que falló.	**MSI silencioso** Un instalador desde %TEMP%, sin ventanas.	**PowerShell oculto** Lo lanza el propio instalador.	**Persistencia** Un binario de .NET registra una extensión en Chrome.	**Conexión al C2** Otro binario de .NET sale por HTTP. Bloqueada: la IP estaba en una lista.	**La alerta** Llega a la consola del SOC.
INFO	INFO	INFO	INFO	INFO	BLOQUEO	ALERTA

Mientras tanto: tres reintentos del pegado y una conexión HTTPS a un segundo C2, sin bloqueo ni alerta.

Lo único que alertó fue un IOC conocido. Todo lo demás estaba en la telemetría como “info”, esperando que alguien lo buscara.

Tiempos relativos al primer pegado (T+0:00), según la telemetría del EDR. Los pasos 1 a 5 quedaron registrados, sin alerta.



Un C2 bloqueado por reputación. Los otros dos salieron sin alerta.

Lo que se encontró, y cómo lo encontró la hunt

LO QUE SE ENCONTRÓ	CÓMO LO ENCONTRÓ LA HUNT	QUÉ QUEDÓ
Un usuario ejecutó un comando pegado desde una web falsa	Explorer escribiendo en RunMRU un comando de descarga	✓ **Detección de ClickFix en RunMRU**
Programas legítimos de Windows usados para conectarse afuera	Binarios del sistema que no deberían tener tráfico de red	✓ **Detección por comportamiento, no por IP**
Una extensión falsa en el navegador que se quedó como persistencia	Un programa que no es el navegador modificando su configuración	✓ **Detección sobre el perfil de Chrome y Edge**

Resumen ejecutivo de la demo: cada hallazgo, la hunt que lo encontró y la detección que dejó.

Una hunt sin informe no existió

El informe es el entregable de la caza. La query se pierde; el informe queda.

Lo lee el que decide	Lo usa el SOC	Lo hereda el próximo hunter	Lo audita el cliente
Gerencia o CISO: qué pasó, qué riesgo hay y qué tiene que aprobar. Lee una página.	Analistas e ingeniería de detección: las queries, los IOCs y las reglas que quedan.	Quien repita la caza en seis meses: qué se buscó, cómo, y qué no se pudo ver.	Cliente o compliance: la prueba de que se buscó, aunque no se haya encontrado nada.

Un informe de hunting responde tres preguntas, encuentre algo o no.

¿Qué pasó?
Hallazgos con veredicto y evidencia.

¿Qué no vimos?
Alcance, limitaciones y nivel de confianza.

¿Qué cambia mañana?
Detecciones, acciones con dueño y la próxima hipótesis.

Informe de ejemplo y plantilla: github.com/Ank1nskywalker/talks

$ exit 0

¡GRACIAS!

Preguntas, dudas, debate.

David Pérez · @anakinswal · perez.edav@gmail.com

Deck, queries y reporte de ejemplo: github.com/Ank1nskywalker/talks

Anexo · Las queries de la demo

```
# 1 · ClickFix en Win+R (RunMRU)
event.type in ('Registry Value Create','Registry Value Modified') and src.process.name = 'explorer.exe' and registry.keyPath contains:anycase 'RunMRU' and
registry.value contains:anycase ('powershell','mshta','curl','iwr','irm','http')
# 2 · Consola oculta (AMSI · Command Script)
event.type = 'Command Script' and cmdScript.content contains:anycase 'GetConsoleWindow' and cmdScript.content contains:anycase ('ShowWindow','FreeConsole')
# 3 · PowerShell oculto hijo de msiexec
event.type = 'Process Creation' and src.process.name = 'msiexec.exe' and tgt.process.name = 'powershell.exe' and tgt.process.cmdline contains:anycase 'hidden'
# 4 · .NET con conexión saliente
event.type = 'IP Connect' and event.network.direction = 'OUTGOING' and src.process.name in:anycase
('csc.exe','ilasm.exe','MSBuild.exe','RegAsm.exe','InstallUtil.exe','AddInProcess.exe')
# 5 · Chequeo de IP pública
event.type = 'DNS Resolved' and src.process.name in:anycase ('powershell.exe','msiexec.exe','csc.exe','ilasm.exe') and event.dns.request in:anycase
('ipinfo.io','ip-api.com','api.ipify.org','ifconfig.me')
# 6 · Perfil del navegador
event.type = 'File Modification' and tgt.file.path contains:anycase 'User Data' and tgt.file.path contains 'Preferences' and not src.process.name in:anycase
('chrome.exe','msedge.exe','setup.exe','GoogleUpdater.exe')
# 7 · Próxima hunt: extensión fuera del navegador (borrador)
event.type = 'File Creation' and tgt.file.path contains:anycase 'manifest.json' and tgt.file.path contains:anycase 'AppData' and not src.process.name in:anycase
('chrome.exe','msedge.exe','setup.exe','GoogleUpdater.exe')
```

SentinelOne, Singularity Data Lake (S1QL). Validá campos y operadores con el autocompletado de la consola: pueden variar entre versiones.

Anexo · Fuentes y referencias

1 · Slide 3 · Rumsfeld, “known knowns” (conferencia de prensa, 12/02/2002)
https://en.wikipedia.org/wiki/There_are_unknown_unknowns
2 · Slide 6 · Sqrrl, “A Framework for Cyber Threat Hunting” (archivo)
https://www.threathunting.net/sqrrl-archive
3 · Slides 6, 7 y 9 · Bianco et al., PEAK Threat Hunting Framework (Splunk SURGe)
https://www.splunk.com/en_us/blog/security/peak-threat-hunting-framework.html
4 · Slide 8 · D. J. Bianco, “The Pyramid of Pain” (2013)
http://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html
5 · Slide 10 · 47 % de los accesos iniciales · Microsoft, Digital Defense Report 2025, p. 37
https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/msc/documents/presentations/CSR/Microsoft-Digital-Defense-Report-2025.pdf
6 · Slide 10 · +517 % y segundo vector · ESET Threat Report H1 2025 (vía Infosecurity Magazine)
https://www.infosecurity-magazine.com/news/clickfix-attacks-surge-2025/
7 · Slide 10 · 4 de 5 desde un buscador · Push Security, “The state of ClickFix” (sep. 2026)
https://pushsecurity.com/blog/the-state-of-clickfix-by-detection-data
8 · Slide 10 · 17.000+ URLs, 3.000 activas · CTM360 (vía SecNews, sep. 2026)
https://www.secnews.gr/en/735682/clickfix-istoselides-pagides-malware/
9 · ATT&CK · T1204.004, User Execution: Malicious Copy and Paste
https://attack.mitre.org/techniques/T1204/004/
10 · ATT&CK · T1176.001, Browser Extensions
https://attack.mitre.org/techniques/T1176/001/

Links consultados el 2 de octubre de 2026. Deck, informe de ejemplo y queries: github.com/Ank1nskywalker/talks